

07 Lack of Resources & Rate Limiting

There is no restriction concerning the number or size of requests which a client is permitted to make when the API has no limits.

Attackers could make use of this by sending a large number of requests, which would cause the system to slow down or crash, allow them to carry out brute-force attacks on passwords or enable them to scrape large amounts of data, and at the same time increase the infrastructure costs.

To prevent this, developers should introduce rate limits, restrict payload and response sizes, set timeouts, and monitor traffic for unusual activity.